

KrakenKeylogger Writeup

Challenge URL: <https://cyberdefenders.org/blueteam-ctf-challenges/krakenkeylogger/>

Difficulty: MEDIUM

Q1: What is the web messaging app the employee used to talk to the attacker?

Answer: Telegram

Explanation: I started by searching the notifications database, located at

`C:\Users\OMEN\AppData\Local\Microsoft\Windows\Notifications\`. Running the command `strings * | grep "tele"` returned the URL `https://web.telegram.org/`.

Q2: What is the password for the protected ZIP file sent by the attacker to the employee?

Answer: @1122d

Explanation: By running the command `strings * | grep "pass"`, the output revealed the following text: `our project templet test.zip,pass:@1122d</text>`.

Q3: What domain did the attacker use to download the second stage of the malware?

Answer: `masheroformasters.cyou`

Explanation:

Following the challenge scenario, I checked the Desktop, Downloads, and Documents folders, where I found the file `templet.lnk`. Using `strings` and `exiftool`, it was clear that this file contained malicious PowerShell commands.

The attacker attempted to hide the download domain by obfuscating it. The weird string found was: `'aht1.sen/hi/coucys.erstmaofershma//s:tpht'`.

I rewrote the decoding logic with clear variable names to understand the process:

Python:

```
def reverse(s):  
    return s[::-1]  
  
def decode(s):  
    r = reverse(s)  
    out = ""
```

```

i = 0
while i < len(r):
    try:
        # Reverse every pair of characters
        out += reverse(r[i:i+2])
    except:
        out += r[i:i+1]
    i += 2
return out

obfuscated = 'aht1.sen/hi/coucys.erstmaofershma//s:tpht'
url = decode(obfuscated)
print("Decoded URL:", url)
# Output: https://masheroftmasters.cyou/chin/sel.hta

```

The PowerShell script performs three main actions:

1. Reverses the entire obfuscated string.
2. Reverses every pair of characters in the resulting string to reveal the actual URL.
3. Downloads the file from the decoded URL using `wget` and executes it.

Q4: What is the name of the command that the attacker injected using one of the installed LOLBAS/LOLAPPS on the machine to achieve persistence?

Answer: `j!hg!jhd!ghjhuhuh`

Explanation:

After researching "LOLAPPS" (Living Off The Land Applications), I investigated the directory `C:\Users\OMEN\AppData\Roaming\` and found a legitimate screenshot tool, **Greenshot**, which was abused for persistence. Analyzing the strings output revealed the following custom configuration:

text

1
2
3

This means that every time the user runs the application, the malware is silently executed via this injected command.

Q5: What is the complete path of the malicious file that the attacker used to achieve persistence?

Answer: `C:\Users\OMEN\AppData\Local\Temp\templet.lnk`

Explanation: This path is directly extracted from the `Argument.jlhgfjhdflghjhuhuh` string in the Greenshot configuration mentioned in Q4.

Q6: What is the name of the application the attacker utilized for data exfiltration?

Answer: AnyDesk

Explanation: While reviewing application artifacts, I found `ad.trace` logs containing an external IP address:

```
info 2023-07-12 08:55:44.878 lsvc 6572 5380 5 anynet.relay_conn -  
External address: 77.232.122.31:3998.
```

This indicates that AnyDesk was used to remotely control and transfer files from the victim's machine.

Q7: What is the IP address of the attacker?

Answer: `77.232.122.31`

Explanation: Extracted directly from the AnyDesk trace file mentioned in Q6.